Threat model · what the design does and does not protect

Risk reduction for low-stakes feedback, not mathematical anonymity. Section numbers refer to SPEC.md.

Designed to prevent

- A second credential for the same account in the same poll §1, §5, §9
- A second response from one credential, or new answers replacing the first §1, §10
- Linking a response to an account through the database or logs §1, §12, §15
- Organisers seeing live counts, who claimed, or any single response §1, §11
- A credential from one poll working in another §6, §17
- Portal cookies or sessions reaching the response site §6, §14
- Script injection through poll text or answers §7, §14
- Editing an open poll, or reopening a closed one §4

Reduced, not eliminated

- Inference from small categories once a question passes 5 answers §1, §11
- Identifying details written into free text (off by default, always optional, warned beside every field) §2, §3
- Losing a credential (durable browser storage, warnings, exact retry of a saved submission) §8
- Timing correlation (no response timestamps or participant logs; the database's own write log and backups remain) §12, §15
- Overload and abuse (rate limits that fail closed, with no IP or device tracking) §14

Out of scope, or must be trusted

- A dishonest operator or issuer minting extra credentials §1
- Operators correlating infrastructure timing or backups §15
- One person controlling several institutional accounts §1
- Sharing or selling a credential; it is a bearer token §2, §3
- Network observers and compromised browsers or devices §2
- Repeated or overlapping polls combined with outside knowledge §2
- Coercion, binding elections and public verification §1, §2
- Availability against a distributed attack §14

Release gate: real participants only after every SPEC.md §18 gate passes (institutional OAuth, native signing, two HTTPS hostnames, logging-compliant hosting, recovery drill). Until then this is a clearly labelled local demo with synthetic accounts, and no anonymity or eligibility claim rests on an unverified deployment assumption.